CoverageProof

Project report

Team CoverageProof Swayam Hiremath

DataOps Innovation Hackathon 2026 PS-1 AI Agent for Automated Penetration Testing

Project overview

CoverageProof helps an analyst track a security assessment. It stores declared checks and their results, keeps original evidence and records approvals before supported execution. A check that failed or never ran stays visible as unfinished work.

Current demonstration

The supplied recording shows two HTTP header checks against an owned local fixture. The home page supports one finding candidate. The admin response contains the expected header. The final report records both completed checks and retains one finding. Planning in this recording uses development rules.

Separate engineering tests cover the Groq provider and native scanner imports. They are described separately from the recorded demonstration.

The Problem

Security tools produce separate results. An analyst still has to work out what those results establish.

A failed check can produce no findings

An unattempted check still needs an answer

Repeated findings need their source evidence

The final report needs clear testing limits

During development, a ZAP startup failure produced no scan output. A later isolated run completed and imported successfully. The assessment must distinguish a failure from a completed check that did not observe a condition. This example comes from project development, not a customer incident.

Your Solution

CoverageProof stores the declared checks, observations and approvals in the same assessment.

Register the request and allowed scope

Import results or run a supported check

Review the proposed follow-up

Approve execution and inspect the result

Download a report linked to source evidence

The main idea is to keep unanswered work visible. The demo checks the home page and then the admin page for the same header condition. One finding remains after both checks finish. The recorded proposal comes from a development rule. Groq planning was evaluated in separate runs.

Project Architecture & Structure

The planner proposes a check. Scope and approval checks control execution.

Browser interface. request, review and approval

Planner. development rules or Groq provider

Backend policy. scope and one-use approval

Adapters. HTTP runner and native scanner imports

SQLite. checks, observations, artifacts and events

Report generator. assessment snapshot to PDF

Implementation uses FastAPI routes, planner and adapter modules, a SQLite store and a PDF renderer. Imported scanner output enters the same evidence store. The current hosted runner performs a bounded HTTP check against its configured fixture. The AI does not directly execute shell commands.

Tech Stack

The project uses existing tools for scanning and focuses on assessment state and evidence.

Python and FastAPI. application backend

Jinja2 and HTML/CSS. browser interface

SQLite. persistent local assessment state

Groq. separately tested model provider

ReportLab. PDF generation

pytest, Playwright and Docker. verification

Groq tests used openai/gpt-oss-120b. The submitted screen recording runs the development provider. Render hosts the demo, while local and isolated Docker runs supported engineering verification. The current free hosted database is temporary.

Features

Both requests tested X-Content-Type-Options on the owned local fixture.

Home page. missing header supports one finding

Admin page before. unattempted

Admin page after approval. header present

Final assessment. two checks and one candidate

Evidence. GET responses, timestamps and approvals

Source is the supplied assessment PDF cfb2c306f3bd449288fd595f75ce8e6f, snapshot a8af60e7d9e24a7d9c0615b7ef00bd91, generated 9 November 2026. The admin state is condition_not_observed. This describes one condition in one response. The finding remains suspected pending analyst review.

Feasibility

The current prototype supports a narrow end-to-end workflow and native result imports.

Recorded demo completes approval, HTTP check and PDF export

Nmap, Nikto and ZAP imports have separate verification runs

Groq selected a declared follow-up in a successful test

Later AI evaluation stopped on provider rate limits

Evidence comes from the supplied demo, assessment report and recorded engineering results in the project conversation. Individual integration proofs do not establish that a combined multi-tool demo has been completed. No measured time saving or AI advantage over the rule baseline is claimed.

Integration status

The table describes the application integration. Separate isolated scanner runs supplied engineering evidence. The hosted demo executes only its bounded HTTP check.

Tool	Application status
Nmap	Import-only
Nikto	Import-only
OWASP ZAP	Import-only
Nessus	Unsupported
OpenVAS / Greenbone	Unsupported
Burp Suite	Unsupported
Metasploit	Unsupported

Limitations

Live AI and combined multi-tool analysis are absent from this video

Nessus, OpenVAS, Burp Suite and Metasploit are unsupported

Risk context can remain unknown and findings need review

The hosted demo uses temporary storage

Organizer lab approval needs separate confirmation

Future Scope

Complete a combined Nmap, Nikto and ZAP assessment

Evaluate AI decisions across more cases and failures

Add retesting to compare results after a fix

Improve persistent storage and team review

Extend supported execution within approved lab boundaries

Evidence and references

The assessment report supplied with the demo is the primary source for its recorded outcome. Assessment cfb2c306f3bd449288fd595f75ce8e6f. Snapshot a8af60e7d9e24a7d9c0615b7ef00bd91. Report time 9 November 2026 at 09:45:13 UTC.

The report contains one low-severity candidate pending analyst review. It has no accepted AI report draft. Impact and exploitability remain unassessed. The owned development scope requires separate organizer approval for evaluation.

PS-1 sections 6, 9 and 10 define the prototype, deliverables and demonstration checklist. Section 11 gives the judging criteria. The organizer presentation announcement specifies the nine-section PPT order.

Repository https://github.com/sevenhiremath/coverageproof

Hosted demo https://coverageproof-demo.onrender.com

The demo requires access credentials. Local setup and execution instructions are in the repository. No credentials are included in this report.